Self Hosted Ghost: ATT&CK threat model summary

Source: Ghost system package (Rev 1.0, 3 Nov 2026) and companion diagram PDF only. No outside sources.

Priority	Findings
High	4
Medium	10
Low	5
Total	**19**

Elements with no distinct threat	1
Elements covered	46

Notes

Rank 1 is highest; equal ranks indicate equal importance.

Priority counts and coverage counts are formulas over the Findings and Coverage sheets.

The Coverage sheet is a checklist, not part of the finding count.

Rank	Finding ID	Affected component / flow	Primary ATT&CK category
1	F01	P2 Post editor (raw HTML card); P1 Admin browser application; DF2, DF3	Privilege Escalation
2	F02	P5 Public site and Content API; DF9	Execution (T1059.007)
3	F03	EE5 Server side publishing script; DF4; P3 Nginx reverse proxy; P4 Admin API	Initial Access (T1078)
4	F04	P1 Admin browser application; DF1, DF3; P4 Admin API	Credential Access (T1557)
5	F05	P7 Email delivery and provider event handling; DF15, DF16; DS1 MySQL core data	Impact (T1565)
5	F06	P4 Admin API authorization (TB6); P2 client-side UI limits (TB2); P9 Publication scheduler; DF3, DF11	Privilege Escalation
7	F07	P4 Admin API; DS1 MySQL core data (integration keys); DF6	Persistence (T1098)
7	F08	P7 Email delivery; P9 Publication scheduler; DF12, DF13, DF14; EE6 Mailgun; EE7 Recipient mailbox service	Initial Access (T1566)
9	F09	DF3; DS1 MySQL core data (session records)	Defense Evasion (T1550.004)
9	F10	EE7 Recipient mailbox service; DF14; P6 Member authentication	Initial Access (T1078)
11	F11	DF6, DF10, DF16 (TB3); DS1 MySQL core data	Credential Access (T1040)
11	F12	P3 Nginx reverse proxy; P5 Public site and Content API; DF9	Impact (T1499)
11	F13	P6 Member authentication; P7 Email delivery; DF9, DF12, DF13, DF14	Impact (T1499)
11	F14	P5 Public site and Content API; P6 Member authentication; DF9, DF10; DS1 MySQL core data; TB6	Initial Access (T1190)

15	F15	P4 Admin API (staff login); DF3	Credential Access (T1110)
15	F16	DS2 S3 public image bucket; DF17	Collection (T1530)
15	F17	P8 S3 image storage adapter; DF7, DF8; DS2 S3 public image bucket	Resource Development (T1608.001)
15	F18	DS3 Server configuration file; DF18; P4, P7, P8	Credential Access (T1552.001)
15	F19	DS4 Local application and proxy logs; DF19; P3 Nginx reverse proxy	Defense Evasion (T1562.006)

Threat mechanism and consequence
A Contributor saves a draft with a script in a raw HTML card. When an Editor or Admin opens or previews it, the script sends Admin API requests under the viewer's session. This lifts the attacker from the lowest staff role to the viewer's role across TB6.
An Author or Editor publishes a post with raw HTML, or an Admin or Owner uses code injection. Persistent script then runs in readers' and members' browsers, enabling phishing overlays, redirects, or actions as a logged-in member.
A holder of the stolen integration key mints valid JWTs and calls the Admin API from anywhere on the Internet. Within the publishing permission set, they publish, alter or delete posts and can plant raw HTML (feeding F02). This bypasses staff password and device verification entirely.
An attacker lures a staff user, especially an Owner or Admin, to a lookalike sign-in page. The attacker relays the password and the new-device emailed code to P4 in real time and obtains a valid server-side session, defeating password hashing, throttling and verification.
An attacker posts forged delivery or engagement events to the callback endpoint via P3. Fake bounces, complaints or unsubscribes suppress newsletter delivery to chosen members and corrupt delivery records in DS1.
P1 and P2 are client components, so a low-privilege user can craft direct API requests instead of using the UI. For example, a Contributor could publish or schedule a draft, or an Author could edit others' posts.
A compromised Admin or Owner session creates a new integration key (or another durable credential). The attacker keeps access through DF4 after the password is reset and sessions are revoked, with no new-device check.
A compromised publisher, or an attacker using the F03 key, sends a newsletter with malicious links to all members from the publication's real Mailgun sender. Members are phished and the sender's reputation is damaged.
A stolen staff session cookie replayed from the attacker's device bypasses the password and new-device verification, which were already satisfied when the session was issued. The attacker acts with the victim's role.
An attacker with access to a member's mailbox redeems the emailed login link first and gets a member session. For staff, mailbox access supplies the new-device code, so it completes a stolen password (see F15).
An on-path attacker reads or alters unencrypted MySQL traffic between the VM and the DB host. This exposes session records, integration keys, member emails and content, and allows tampering.
An attacker floods public routes such as content requests and link redemption. A single VM and a single Node server with no WAF saturate, taking the site and admin offline.
An attacker repeatedly requests member sign-in or signup for victim addresses. Ghost sends mail through Mailgun to third parties, which mail-bombs victims, burns Mailgun capacity and reputation, and can delay legitimate staff codes and member links.
Crafted requests to the public Content API or member endpoints return unpublished or scheduled posts or other members' data, or manipulate queries against DS1.

An attacker guesses or stuffs staff passwords against the login. Throttling exists but its threshold is unspecified. A correct password still faces new-device verification.
Images for unpublished drafts are publicly readable by URL with no Ghost authorization. Anyone who obtains a URL sees pre-publication images.
A staff-uploaded file that passes image validation but carries active or deceptive content is served publicly from the bucket under the publication's trusted URLs, as a phishing or malware lure.
An attacker who reads the config file gets plaintext DB, Mailgun and S3 credentials. They can send mail as the publication, overwrite or delete public images, and reach the DB if routable.
An attacker generates high-volume noise such as failed logins and junk requests so local-only logs fill or rotate. This masks later activity such as F03 or F09 abuse, and there is no off-box archive or monitoring to preserve or alert.

Required initial attacker access	Additional assumption	Priority
Compromised Contributor (or Author) account	Raw HTML in drafts runs as active script in an origin that carries the viewer's staff session, and a privileged user views the draft. HttpOnly cookies do not stop same-origin requests.	High
Compromised Author or Editor (HTML card), or Admin or Owner (code injection)	None. The package enables both features and makes no claim that active content is stripped.	High
Stolen integration Admin API key	The key has no network restriction or rotation beyond JWT lifetime. How the key was stolen is not modeled.	High
Anonymous Internet attacker plus victim interaction	Staff can be lured to an attacker-controlled domain. The stated factors are password plus emailed code, with no phishing-resistant factor.	High
Anonymous Internet attacker	Event authentication is absent or bypassable (the package does not credit signature validation). The attacker knows the callback path and valid member addresses.	Medium
Compromised Contributor or Author account (or free member, for staff-only endpoints)	The server-side role or ownership check has a gap on some endpoint or status transition. The package states that checks exist.	Medium
Compromised Admin or Owner session	Integration keys stay valid after staff credential or session remediation, and creating one needs no re-authentication.	Medium
Compromised Editor, Author or Admin, or stolen integration key	Publishing triggers a newsletter send to members, and newsletter content allows attacker links or raw HTML.	Medium
Stolen staff session cookie	Sessions are not bound to a device or network, and session lifetime and revocation are not specified.	Medium
Control of the victim's mailbox (mailbox internals are out of scope)	The mailbox is compromised by means outside the package.	Medium
Network foothold on the private segment	Database TLS is not used (the package does not assume it) and the attacker has a network position, which is not among the listed attacker accesses.	Medium
Anonymous Internet attacker	There are no rate or capacity limits on public routes beyond the stated login throttling.	Medium
Anonymous Internet attacker	Member link and signup requests are not throttled per address or IP. The package states throttling only generally for login.	Medium
Anonymous Internet attacker or free member	P5 or P6 has an input-handling or published-only filtering flaw. The package states validation and authorization only for the Admin API.	Medium

Anonymous Internet attacker	Staff passwords are reused or weak, and distributed attempts evade throttling. The attacker must also satisfy new-device verification (see F04, F10).	Low
Anonymous Internet attacker holding an object URL	The URL leaks or is guessable. Bucket listing is disabled, so enumeration is not possible.	Low
Compromised staff account that can upload images	Validation accepts a scriptable, polyglot or mismatched file type.	Low
An application-level file-read primitive (not defined in the package)	The credentials are plaintext and readable by the Ghost process, and the read primitive exists. Host exploitation is excluded.	Low
Anonymous Internet attacker	Local log retention is size- or time-limited, or the disk can fill. Neither is specified.	Low

Priority justification
It crosses the role boundary from the weakest staff role to Admin or Owner, and the package states raw HTML is enabled with no claim of stripping.
It reaches every visitor and the only precondition is a staff account that can already publish.
It is a machine credential with no human-verification step, reachable over the Internet. The publishing-only permission set limits blast radius but not content integrity.
It is a realistic route to Owner or Admin takeover from the Internet, and it defeats the layered sign-in controls.
No credentials are needed and it writes to DS1, but the impact is limited to delivery state and metrics.
The consequence is unauthorized publication, but it depends on a flaw in a stated control.
The attacker already holds high privilege, but persistence makes incident recovery much harder.
It reaches the whole member list through a trusted channel, but needs prior privileged access.
It bypasses every sign-in control, but HttpOnly reduces script-based theft and exposure depends on session lifetime.
Member impact is low because members never get staff privileges, but it completes the staff two-step flow when the password is known.
Impact is very high, but it requires a foothold that is not in the stated attacker set.
It is trivial to attempt and the architecture has no stated absorption layer, but it is an availability impact only.
It is cheap and abuses a trusted sender, and it can degrade the authentication mail path.
It is the main public attack surface and DS1 holds sensitive data, but it rests on an assumed flaw.

Throttling, hashing and the verification step all apply, so a password alone is not enough.
The exposure is limited to images and needs the URL.
It depends on a validation gap, and bucket-hosted content does not carry site session context.
The blast radius is large, but no in-scope path to the file is established.
It does not cause harm directly, but it degrades detection of the higher-ranked threats.

Element ID	Type
EE1	External entity
EE2	External entity
EE3	External entity
EE4	External entity
EE5	External entity
EE6	External entity
EE7	External entity
P1	Process
P2	Process
P3	Process
P4	Process
P5	Process
P6	Process
P7	Process
P8	Process
P9	Process
DS1	Data store
DS2	Data store
DS3	Data store
DS4	Data store
DF1	Data flow
DF2	Data flow
DF3	Data flow
DF4	Data flow
DF5	Data flow
DF6	Data flow
DF7	Data flow
DF8	Data flow
DF9	Data flow
DF10	Data flow
DF11	Data flow
DF12	Data flow
DF13	Data flow
DF14	Data flow
DF15	Data flow
DF16	Data flow
DF17	Data flow
DF18	Data flow
DF19	Data flow
TB1	Trust boundary
TB2	Trust boundary
TB3	Trust boundary
TB4	Trust boundary
TB5	Trust boundary
TB6	Trust boundary

TB7	Trust boundary

Component / flow
Staff user including Contributor, Author, Editor
Owner or Administrator
Free member
Anonymous reader
Server side publishing script
Mailgun email provider
Recipient mailbox service
Admin browser application
Post editor including session save engine and publish UI
Nginx reverse proxy
Admin API including staff authentication validation authorization and serialization
Public site and Content API
Member authentication
Email delivery and provider event handling
S3 image storage adapter
Publication scheduler
MySQL core data
S3 public image bucket
Server configuration file
Local application and proxy logs
EE1,EE2 to P1
P1 to P2
P1,P2 to P3
EE5 to P3
P3 to P4,P5,P6,P7
P4 to DS1
P4 to P8
P8 to DS2
EE3,EE4 to P3
P5,P6 to DS1
P4 to P9
P9,P6,P4 to P7
P7 to EE6
EE6 to EE7
EE6 to P3
P7 to DS1
EE3,EE4 to DS2
DS3 to P4,P7,P8
P3,P4,P6,P7 to DS4
Internet to Nginx
User controlled staff browser or external script to server
Ghost VM to MySQL host
Ghost or public clients to S3
Ghost to Mailgun, including inbound event callbacks
Authorization levels inside Ghost

Email provider to recipient mailbox

Associated finding IDs	Finding count
F01, F02, F04, F06, F08, F09, F15	7
F02, F04, F07, F08, F09, F15	6
F02, F10, F13, F14, F16, F17	6
F02, F12, F14, F16, F17	5
F03	1
F05, F08, F13	3
F08, F10, F13	3
F01, F04, F06, F09	4
F01, F06	2
F03, F05, F12, F19	4
F01, F03, F06, F07, F09, F15, F17, F18	8
F02, F12, F14	3
F10, F13, F14	3
F05, F08, F13, F18	4
F17, F18	2
F06, F08	2
F05, F07, F09, F11, F14	5
F16, F17, F18	3
F18	1
F19	1
F04	1
F01	1
F01, F04, F06, F09, F15	5
F03	1
No distinct threat identified (loopback forwarding; interception would require excluded host access)	0
F07, F11	2
F17	1
F17, F18	2
F02, F10, F12, F13, F14	5
F11, F14	2
F06	1
F08, F13	2
F08, F13	2
F08, F10, F13	3
F05	1
F05, F11	2
F16	1
F18	1
F19	1
F03, F05, F12, F14	4
F01, F03, F04, F06, F09	5
F11	1
F16, F17, F18	3
F05, F08, F13	3
F01, F06, F14	3

F10	1